

these vulnerabilities and have weaker defences—are attacked in order to gain access to them. Once in, all traces of the break-in are wiped out, and special replacement tools called rootkits are installed. These prevent other root users (or administrators) from locating and removing the unauthorised intruders. In the next step, the perpetrator of the attack shifts focus to using the compromised machine as a platform for further attacks, by deploying a remote-control tool on the compromised machine. With this machine in control, the perpetrator can further target other machines, using this machine to progressively scan and probe and break into more systems and networks, and install the same remote-control tools.

Most attacks are generally non-OS-specific—the tools used to break into and acquire control of these computers could be ported into the OS and architecture of choice. Now here comes the scary part: with the kind of widely available automated tools, including worms that can be written for known vulnerabilities, it would take less than 5 seconds to compromise a single machine—meaning that several thousand hosts can be attacked, and taken over in less than an hour.

Blastin' its Way

In July 2003, Microsoft acknowledged a vulnerability in their Windows NT, 2000, XP and Server 2003 related RPC (Remote Procedural Call) implementation. A buffer overflow mechanism was detected over the part of the RPC implementation that dealt with message passing. A successful attack would grant the remote intruder full administrator access on the local system.

MSBlast takes advantage of this vulnerability, and gains access to the target system. The worm then retrieves a copy of a file named msblast.exe, executes it and starts scanning for other vulnerable hosts. The infected computers reboot with a 60 second timeout. With Internet access available, the worm is coded to target a SYN flooding attack at the official Microsoft update site (www.windowsupdate.com) on port 80, if the current date is the 16th or later (from January through August), or any day of the month between September and December. The only solution here is to patch up the OS; a free removal tool is available at <http://securityresponse.symantec.com/avcenter/venc/data/w32.blaster.worm.removal.tool.html>

But wait up, the show is just starting—the final step is the actual DDoS attack. Each one of these compromised machines are called zombies in SysAdmin-speak, and with an informal network of thousands of zombies, each one can be ordered to attack a given target using a variety of techniques. The attacker can control each zombie with just a single command, and instruct them to launch any type of attack. Turning off the attack is as simple as issuing another command. As the examples of some of the most ferocious attacks in Internet history will show you, the attempt succeeds because the co-ordinated effort across numerous slave machines overwhelm the resources of the victims.

If this dangerous sequence of steps was done under manual supervision and control, the number of computers that could be compromised would be limited to what the cracker could handle. But take this technique and automate it down to one self-propagating program—a worm that will mindlessly follow the directives programmed into it, millions of times over—and that is the nature of the world's most destructive Internet DDOS attacks.

Slamming it down, hard

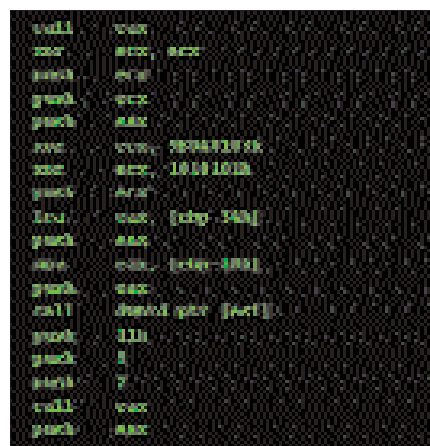
The Slammer attack that struck around the 25th of January 2003 hit all the records, and went down in history as the fastest computer worm ever. Slammer is a slickly crafted worm that takes up a mere 376 bytes of memory. The worm took advantage of a rather common flaw that can potentially exist in most applications, known as buffer overflow.

During normal operation, code is read into the system memory and occupies certain real estate there i.e., allocated memory blocks called buffers. A buffer overflow happens when too much data is pushed into a buffer. After the buffer fills up, the data being read wipes out the program code in the neighbouring blocks, and substitutes that code with the new code. This is where arbitrary code can be fed into the system and malicious instructions executed.

Slammer exploited a stack buffer overflow flaw in Microsoft's SQL Server: the worm pumped data into the server, way beyond what it was legitimately allotted. As a result, other data got read into memory space where it was not supposed to. This effectively let Slammer give new instructions to the host computer—the ones Slammer used to propagate itself—which the computer executed.

This security loophole had already

been identified in July 2002; patches that resolved this had been released by Microsoft before the public announcement of the vulnerability. Slammer managed to get through anyway, because not enough people had patched up, early enough. It used some pretty smart tricks to ensure rapid infection. The infected population was estimated to double roughly every 8.5 seconds. It used random IP scanning, to zero-in on other computers all over the Internet. Just one 376 byte UDP packet (the kind used to send information across the Net) destined for UDP port 1434 spread



Slammer: 376 bytes long, spreading world-wide, coming to a computer near you

across millions of random IP addresses, and ultimately infected an estimated 75,000 hosts. Networks all over the world started going out as each infected machine spewed out more packets to random IP addresses, as fast as network connectivity would allow; the sheer volume of senseless traffic being put out was bringing down networks in North America, Europe and Asia. In the US, ticketing and schedules of the domestic airline, Continental Airlines were disrupted; Seattle's law enforcement and emergency response units went offline and the employees found themselves back in the early 20th century with radio sets and pencils; the 13,000-strong ATM network of Bank of America went on the blink; and many Internet sites went offline as their servers were swamped by traffic. All of South Korea and many parts of Europe went offline, and five of the Internet's root servers—the Internet's version of a lookup directory service—went down.

Despite the havoc, Slammer did not seem to contain any destructive payload, and has not appeared to have destroyed any computer files. Still, a worm that spread over the world in roughly 10 min-